EAST TEXAS A&M UNIVERSITY

CSCI 352.61E
DIGITAL FORENSICS

System Forensics, Investigation, and Response

Lesson 13

Incident and Intrusion Response

Learning Objective

- Describe incident and intrusion response.

Key Concepts

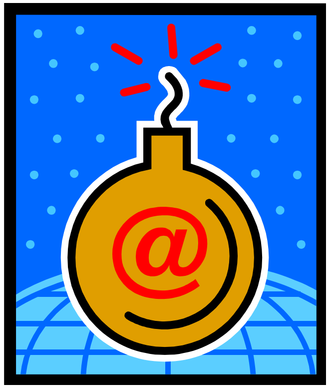
- Disaster recovery
- Evidence preservation
- How to integrate forensics to incident response

What Is Disaster Recovery?

- Steps taken after an information technology-related disaster to restore operations
- Forensic techniques may be best method for determining what caused the disaster and for avoiding a repeat of it
- Forensic process begins once an incident has been discovered
  - Is not fully underway until after the disaster or incident is contained

Incident Response Plan

- In place to respond to:
  - Fire
  - Flood
  - Hurricane
  - Tornado
  - Hard drive failure
  - Network outage
  - Malware infection
  - Data theft or deletion
  - Intrusion



Business Continuity, Incident Response, and Disaster Recovery

Types of Plans

- Business continuity plan (BCP)
  - Focuses on keeping an organization functioning as well as possible until a full recovery can be made
- Disaster recovery plan (DRP)
  - Focuses on executing a full recovery to normal operations
  - Sometimes referred to as an incident response plan (IRP)

Types of Plans (Cont.)

- In other words:
  - **BCP** concerned with **maintaining at least minimal operations** until organization can be returned to full functionality
  - **DRP** focuses on **returning to full functionality**

Federal Standards for BCPs

- ISO 27001
- NIST 800-34
- NFPA 1600

Federal Standards for BCPs (Cont.)

- ISO 27035
- NIST 800-61

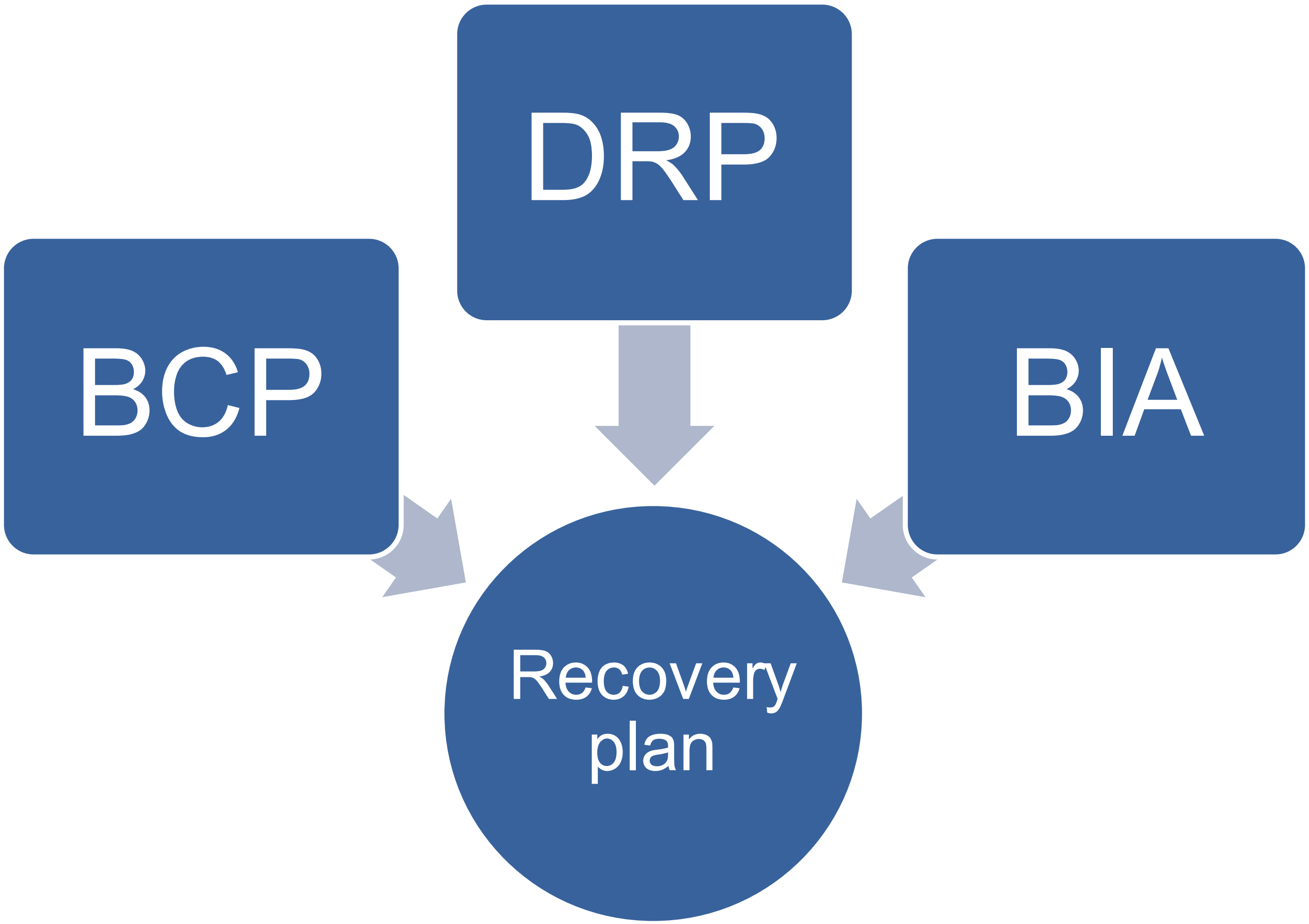
Business Impact Analysis (BIA)

- A study that identifies the effects a disaster would have on business and IT functions
  - Studies include interviews, surveys, meetings, and so on
- Identifies the priority of different critical systems
- Considers maximum tolerable downtime (MTD)

Maximum Tolerable Downtime (MTD)

- A measure of how long a system or systems can be down before it is impossible for the organization to recover
- Related to:
  - Mean time to repair (MTTR) – The average time it takes to repair an item
  - Mean time to failure (MTTF) – The amount of time, on average, before a given device is likely to fail through normal use

The Recovery Plan



The Recovery Plan (cont.)

1. Alternate equipment identified?
2. Alternate facilities identified?
3. Mechanism in place for contacting all affected parties, employees, vendors, customers, and contractors, even if primary means of communication are down?
4. Off-site backup of the data exists?
5. Can backup be readily retrieved and restored?

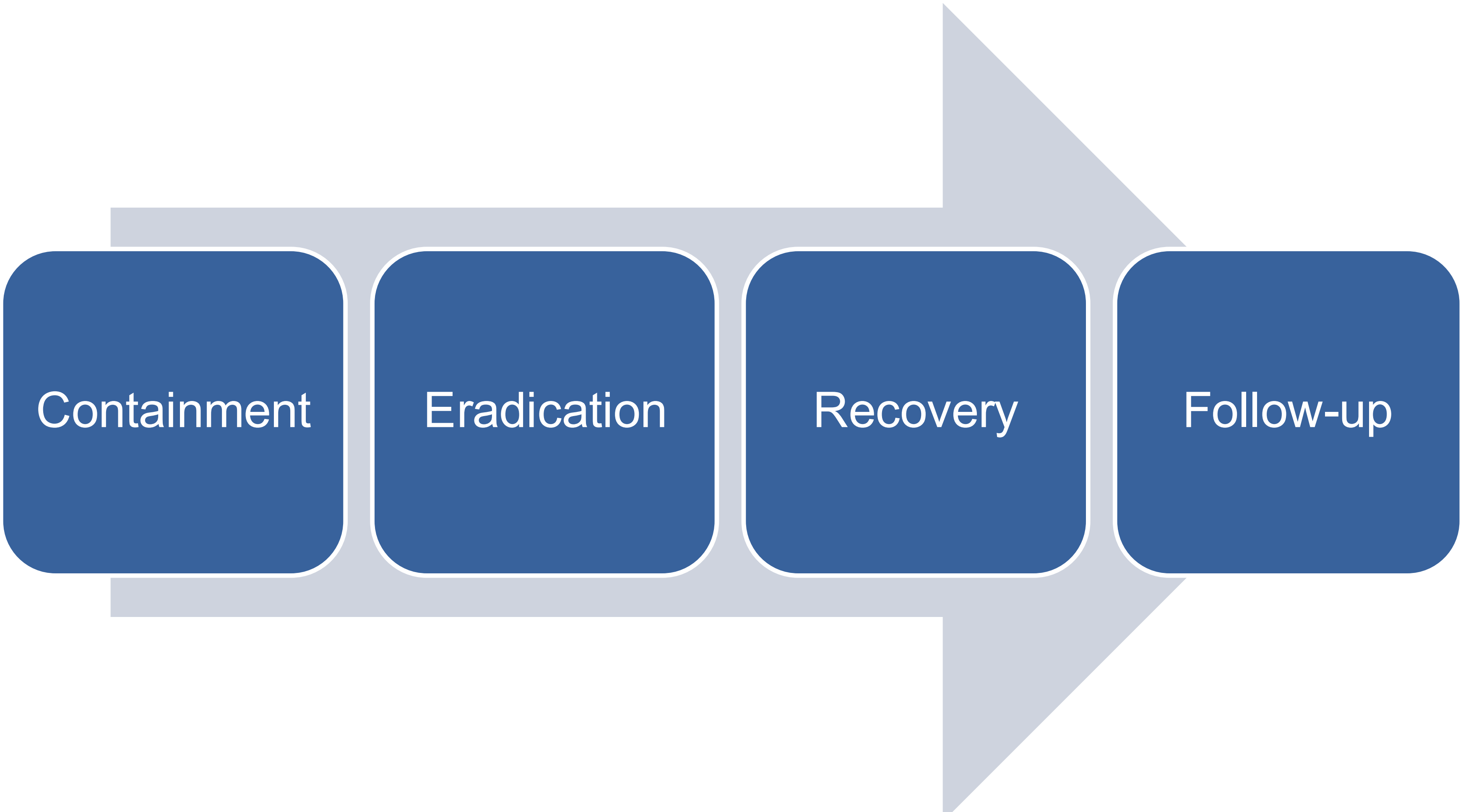
Types of Backups

- Full – All changes
- Differential – All changes since the last full backup
- Incremental – All changes since the last backup of any type
- Hierarchical storage management (HSM) – Continuous backup

The Post-Recovery Follow-Up

- After recovery, find out **what** happened and **why** (involves forensics):
  - Was disaster caused by some weakness in the system?
  - Negligence by an individual?
  - A gap in policy?
  - An intentional act?

Incident Response



Containment

- Limit the incident
- Prevent it from affecting more systems

Eradication

- Fix vulnerabilities
  - Example: Remove the malware
- Perform comprehensive examination of what occurred and how far it reached
- Ensure that the issue was completely addressed

- Forensics begins at this stage

Recovery

- Involves returning the affected systems to normal status
- If malware:
  - Ensure the system is back in full working order with no presence of malware
  - Might need to restore software and data from backup

Follow-up

- Forensics plays a critical role
- IT team must determine:
  - How incident occurred
  - What steps can be taken to prevent incident from reoccurring

Preserving Evidence

- An event:
  - Is any observable occurrence within a system or network
  - Includes network activity, such as when a user accesses files on a server or when a firewall blocks network traffic
- Adverse events have negative results or negative consequences
  - Example: An attack on a system

Computer Security Incidents

- Denial of service (DoS) attacks
- Malicious code
- Unauthorized access
- Inappropriate usage

Preserving Evidence (Cont.)

- Recovery often performed at the expense of preserving forensic evidence
- Failure to preserve forensic information:
  - Prevents IT team from effectively evaluating cause of incident
  - Makes it difficult to modify company policies and procedures to reduce risk
- Forensic data is key to preventing future incidents

Adding Forensics to Incident Response

- Identify forensic resources the organization can use in case of an incident
- Identify an outside party that can respond to incidents with forensically trained personnel
- Weave forensic methodology into organization's incident response policy
- Provide appropriate training to staff for preserving evidence

Summary

- Disaster recovery
- Evidence preservation
- How to integrate forensics to incident response

THANK YOU

Yau Ka Cheung
Yauka.Cheung@etamu.edu
ACB1 Room 335